



Risk Management

AGENDA

1. ¿Qué es la gestión de riesgos?
2. Marcos para la gestión de riesgos
3. Evaluación de los riesgos de seguridad de la información
4. Mecanismos de tratamiento de riesgos
5. Monitoreo y revisión de riesgos

INTRODUCCIÓN

Risks abound in the world of information security. From hackers and malware to lost devices and missing security patches, information security professionals have a lot on their plate. Of course, addressing each risk takes both time and money. Risk management is the practice of identifying, assessing, and treating the risks facing an organization.



The main responsibility of a cybersecurity professional is to manage risk. Organizations face many different kinds of risk, and it's your job to identify, assess, and manage those risks to protect your information and assets. This section discusses the different kinds of risk that exist in our everyday world.

Internal and External Risks

Risks can be divided into two categories: internal and external. Internal risks are those that arise from within the organization. For example, if the way that you process checks creates an opportunity for employees in the accounting department to commit fraud, then that's an example of an internal risk.

RISK TYPES

Multiparty Risks

These are risks that are shared among many different organizations. For example, if a software as a service (SaaS) provider is compromised, that is a multiparty risk because it poses a risk to all the customers of that service provider.

Specific Risks

1. *Legacy Systems*

Legacy systems pose a unique type of risk to the organization. These systems have been around for a long time and remain in use despite their age and possible lack of maintenance.

2. *Intellectual Property*

In the information age, the value delivered by many businesses resides in their intellectual property.

3. *Software License Compliance*

Finally, make sure that you consider the risks associated with software license compliance issues. Businesses often go to great lengths to protect their intellectual property investment in software, including performing audits of organizations and assessing significant fines to those who violate license agreements.

RISK IDENTIFICATION AND ASSESSMENT

The world of cybersecurity is full of risks. As a result, you have to figure out how to allocate your limited time and resources to address the most important risks first. To accomplish this, you need to prioritize your risk lists so that you spend your precious resources where they will have the greatest security impact.

Risk identification and assessment is the process of identifying and triaging the risks facing an organization based on the likelihood of their occurrence and their expected impact on the organization.

THE LANGUAGE OF RISK

First, we need a common language. In everyday life, people often use the terms *threat*, *vulnerability*, and *risk* interchangeably. However, they are actually three different concepts:

- ▶ *Threats* are external forces that jeopardize the security of your information and systems. Threats might be naturally occurring, such as hurricanes and wildfires, or human-made, such as hacking and terrorism. You can't normally control what threats are out there. They exist independently of you and your organization.
- ▶ *Vulnerabilities* are weaknesses in your security controls that a threat might exploit to undermine the confidentiality, integrity, or availability of your information or systems. These might include missing patches, promiscuous firewall rules, or other security misconfigurations. You *do* have control over the vulnerabilities in your environment, and security professionals spend much of their time hunting down and remediating vulnerabilities.

THE LANGUAGE OF RISK

- *Risks* occur when your environment contains both a vulnerability and a corresponding threat that might exploit that vulnerability, as shown in Figure 4.1. For example, if you haven't patched a database server recently and hackers create malware that exploits an unpatched vulnerability, you face a risk. You are vulnerable because you're missing a security control and there is a threat: the new malware.



FIGURE 4.1 Risks are the combination of a threat and a corresponding vulnerability

RANKING RISKS

Once you've identified the risks facing your organization, you probably still have a somewhat overwhelming list. The next stage in the process ranks those risks by two factors:

Risk Likelihood

The *likelihood* of a risk is the probability that it will actually occur. For example, there is a risk of earthquake in both California and Wisconsin. When you look at the data, however, you find that the probability of an earthquake occurring is far higher in California, where almost 5,000 significant earthquakes occurred over a 25-year period. During that same time, Wisconsin didn't experience a single major earthquake. Therefore, security professionals in California must be hypervigilant about the risk of earthquakes, while those in Wisconsin can probably ignore it.

Risk Impact

The *impact* of a risk is the amount of damage that will occur if the risk materializes. For example, an earthquake might cause devastating damage to a data center, while a rain-storm might not cause any damage at all.

In risk assessments, two categories of techniques are available for assessing the likelihood and impact of a risk: qualitative techniques and quantitative techniques.

Qualitative techniques use subjective judgments to assess risks, typically categorizing them as low, medium, or high on both the likelihood and impact scales. Figure 4.2 shows an example of a qualitative risk assessment matrix. When considering a specific risk, the assessor first rates the likelihood as low, medium, or high, and then does the same for the impact. The chart then categorizes the overall risk. For example, a risk with a high likelihood and high impact would be categorized as a high risk, whereas a risk with a medium likelihood and low impact would be categorized overall as low.

Quantitative techniques use objective numeric ratings to assess the likelihood and impact of a risk. When performing a quantitative risk assessment, you'll do some mathematical calculations to determine the precise amount of financial damage you can expect from a given risk in any typical year.

RISK ASSESSMENT TECHNIQUES

A qualitative risk assessment matrix with 'LIKELIHOOD' on the horizontal axis and 'IMPACT' on the vertical axis. The matrix is a 4x4 grid of colored cells. The colors represent risk levels: blue for 'LOW', yellow for 'MEDIUM', and red for 'HIGH'. The diagonal cells (top-left to bottom-right) are blue, indicating low risk. Cells above the diagonal are yellow, indicating medium risk. Cells below the diagonal are red, indicating high risk. The bottom-right cell is yellow, indicating medium risk.

		LIKELIHOOD		
IMPACT		LOW	MEDIUM	HIGH
	HIGH	MEDIUM	HIGH	HIGH
	MEDIUM	LOW	MEDIUM	HIGH
	LOW	LOW	LOW	MEDIUM

FIGURE 4.2 Qualitative risk assessment

RISK TREATMENT STRATEGIES

Once you complete a risk assessment for your organization, you're left with a prioritized list of risks that require your attention. Risk treatment is the process of systematically analyzing potential responses to each risk and implementing strategies to control those risks appropriately.

No matter which risk you're managing, you have four basic options for addressing the situation.

You can:

4 Risk Response Strategies

Avoid

Transfer

Mitigate

Accept

Risk Avoidance

When you practice risk avoidance, you change your organization's business practices so that you are no longer in a position where that risk can affect your business.

For example, imagine that you performed a risk assessment of the risk that flooding posed to your organization's data center. If you chose to pursue a risk avoidance strategy for that risk, you might relocate your data center to a facility where there is no risk of flood damage.

Risk Transference

Risk transference attempts to shift the impact of a risk from your organization to another organization. The most common example of risk transference is an insurance policy.

Many organizations are now considering the purchase of cybersecurity insurance policies to protect against the financial damage caused by hackers and identity theft. It's important to remember, however, that you can't always transfer a risk completely. For example, you can purchase insurance to cover the financial damage caused by a security breach, but no insurance policy can repair your business's reputation in the eyes of your customers.

In the flood risk example, you might transfer the financial risk of your data center flooding from your organization to an insurance company by purchasing flood insurance.

Risk Mitigation

Risk mitigation takes actions designed to reduce the likelihood and/or impact of a risk. If you want to mitigate the risk of your data center flooding, you might engage a flood control specialist to install systems designed to divert water away from your facility.

Risk Acceptance

In almost every risk assessment, managers find themselves confronted with a very long list of risks and inadequate resources to avoid, transfer, or mitigate all of them. For business reasons, they must accept some of those risks.

Risk acceptance should only take place as part of a thoughtful analysis that determines that the cost of performing another risk management action outweighs the benefit of controlling the risk.

In the flooding scenario, you might conclude that all of the other risk management options are too costly and decide to continue operations in your current facility as is and deal with the aftermath of a flood should it occur.

RISK TREATMENT STRATEGIES RISK PROFILE AND TOLERANCE

Every organization must choose the appropriate mix of risk treatment strategies for their own technical and business environment. The combination of risks that affect an organization are known as its risk profile, and the organization adopts risk treatment strategies to address the risks in that profile.

The initial level of risk that exists in an organization before any controls are put in place is the organization's inherent risk. Then controls are applied to reduce that risk, but, of course, not every risk can be completely eliminated. The risk that remains after the inherent risk is reduced by controls is known as the residual risk.

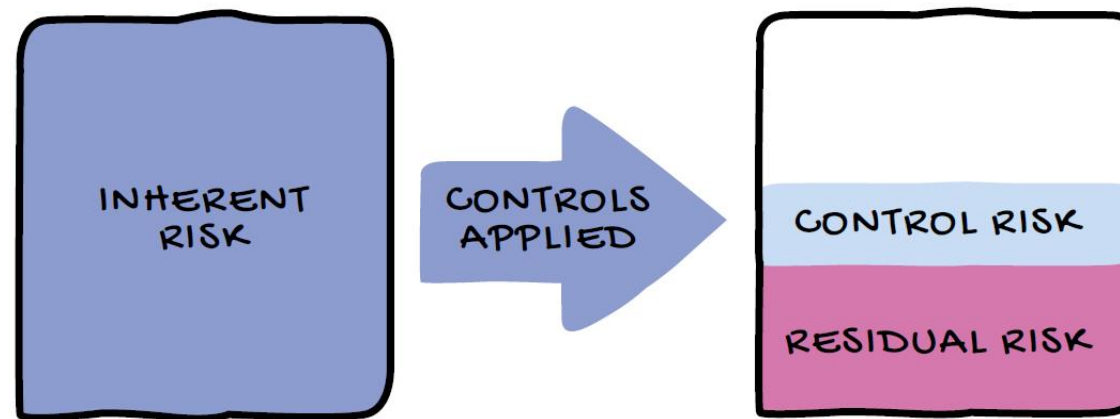


FIGURE 4.3 Applying controls reduces the inherent risk down to the residual risk but also introduces control risk.

THE RISK REGISTER

A Risk Register is a centralized record used in risk management to document and track identified risks, their analysis, and actions to address them.

- Captures all known risks in one place
- Includes risk description, likelihood, impact, and owner
- Helps monitor mitigation plans and responses
- Supports decision-making and accountability



RISK TREATMENT STRATEGIES RISK PROFILE AND TOLERANCE

EXAM ESSENTIALS

- ▶ Internal risks are those that arise from within the organization. External risks are those where the threat originates outside of the organization. Multiparty risks are shared among many different organizations.
- ▶ Threats are external forces that jeopardize the security of your information and systems. Vulnerabilities are weaknesses in your security controls that a threat might exploit to undermine the confidentiality, integrity, or availability of your information or systems. Risks occur when your environment contains both a vulnerability and a corresponding threat that might exploit that vulnerability.
- ▶ Risks are prioritized based on their likelihood and impact. The likelihood of a risk is the probability that it will actually occur. The impact of a risk is the amount of damage that will occur if the risk materializes.
- ▶ Qualitative risk assessment techniques use subjective judgments to assess risks, typically categorizing them as low, medium, or high on both the likelihood and impact scales. Quantitative risk assessment techniques use objective numeric ratings to assess the likelihood and impact of a risk.
- ▶ The four risk treatment options are avoiding a risk, transferring a risk, mitigating a risk, and accepting a risk.
- ▶ An organization's risk profile begins with its inherent risk. Security professionals then apply controls to reduce that inherent risk, leaving the remaining residual risk. Controls may introduce new control risks.

RISK IDENTIFICATION EXAMPLE

Plantilla

Debido a **[fuente de riesgo o causa]**, podría presentarse **[evento]**, afectando **[activo, proceso u objetivo]** y generando **[consecuencias]**.

Ejemplo:

Debido a la ausencia de autenticación multifactor en las cuentas administrativas, un atacante que obtenga credenciales válidas podría acceder sin autorización a los sistemas críticos, ocasionando interrupciones operativas, pérdida de confidencialidad de la información e incumplimiento de obligaciones regulatorias, lo cual afectaría el objetivo de mantener la continuidad y seguridad de los servicios tecnológicos.

Gracias